SFT/1 协议说明

连接及信任

底层是TCP，上层必须完成TLS 1.3双向身份认证。唯一允许的算法配置：

```
signature_algorithms: ed25519
supported_groups: X25519
cipher_suites: TLS_AES_256_GCM_SHA384
ALPN: sft/1
session tickets: 0
session cache: disabled
early data: 0
```

本地固定公钥认证策略替代CA信任链策略：从对端证书提取原始Ed25519公钥，必须与本地信任列表中的32字节公钥匹配；同时检查证书有效期及自签名。TLS的CertificateVerify/Finished按标准验证握手身份、上下文与密钥持有情况。无证书、非Ed25519、未知公钥、认证失败都进不了应用协议。

握手由OpenSSL负责：临时X25519共享秘密通过TLS 1.3 HKDF-SHA384派生密钥，Ed25519认证握手transcript；AES-GCM nonce、双向序列号和AAD由TLS记录层管理。应用层不传送明文AES密钥，不保存会话密钥，不实现独立nonce计数器。

每个TCP连接创建新的`SSL`对象，从未设置旧`SSL_SESSION`，握手完成后还检查`SSL_session_reused == 0`。每发送256 MiB请求KeyUpdate，也允许客户端`rekey`触发；文件边界不重置TLS记录序列号。TLS1.3 KeyUpdate更新流量密钥，不是重新进行X25519；需要全新协商时使用重连。

应用帧

TLS解密后的字节流按如下格式分帧，所有多字节整数均为无符号大端整数：

字段	字节数	值
magic	4	ASCII `SFT1`
version	2	`1`
type	2	`1`到`5`
payload_length	4	`0`到`262144`
payload	指定长度	按类型解析

必须完整读取12字节帧头，检查版本、类型和长度后再分配帧体。允许任意TCP/TLS分段或合并，禁止根据`recv`返回次数推断消息边界。连接按请求顺序处理，不支持流水线文件传输；不存在未完成操作跨连接延续的情况。

类型	数值	帧体
Command	1	字符串字段数组
Response	2	两个字符串字段：`OK`/`ERROR`，消息
FileMeta	3	8字节精确文件大小
FileData	4	1到65536字节原始文件数据
FileEnd	5	32字节SHA-256摘要

字符串字段数组：2字节字段数（1到16），随后每字段为4字节长度+对应原始UTF-8字节；必须恰好解析完帧体，不允许多余数据。

命令编码

命令	字段
ls	`ls`
pwd	`pwd`
cd	`cd`, 远端路径
mkdir	`mkdir`, 远端路径
rm	`rm`, 递归标志`0`/`1`, 远端路径
upload	`upload`, 覆盖标志`0`/`1`, 远端路径, 十进制精确字节数
get	`get`, 远端路径
rekey	`rekey`，TLS KeyUpdate已由客户端触发
exit	`exit`

客户端的引号解析、`get -o`本地改名、`reconnect`和`help`属于本地交互，不直接作为这些格式之外的网络命令。

网络路径中的`/`表示共享根目录，其他路径相对于会话工作目录；`..`不得越过根。文件名做跨平台字符和设备名检查，不传输本机真实磁盘路径。

状态机

建连

```
TCP → fresh TLS mutual authentication → server Response(OK, /) → idle
```

客户端收到服务端应用层欢迎响应后才报告连接完成，这也确认服务端已接受客户端身份。新会话的工作目录总是`/`。

上传

```
client Command(upload, overwrite, path, size)
server Response(ERROR, reason) → idle
或者:
server Response(OK, SUCCESS_START_SEND)
client FileData × N（字节数总计必须正好 size；空文件 N=0）
client FileEnd(sha256)
server 校验、刷新、原子提交文件
server Response(OK, SUCCESS_FINISH_RECV) → idle
```

下载

```
client Command(get, path)
server Response(ERROR, reason) → idle
或者:
server FileMeta(size)
client Response(ERROR, reason) → idle
或者:
client Response(OK, SUCCESS_READY)
server FileData × N
server FileEnd(sha256)
client 校验、刷新、原子提交文件
client Response(OK, SUCCESS_FINISH_RECV)
server Response(OK, SUCCESS_SEND_FINISH) → idle
```

进入文件流后出现长度、帧类型、SHA-256、I/O或TLS错误，关闭该连接，不尝试在剩余字节流中重新寻找命令边界。接收端尚未提交的临时文件由析构清理。其他请求在idle中验证失败时返回`ERROR`，可以继续使用连接。

TCP EOF/超时→清理连接→在新连接重新认证、协商新密钥。失败命令没有自动重放；确认丢失时结果可能已经提交。本版本不提供跨断线"恰好一次"语义或断点续传。

标准参考

- RFC 8446：TLS 1.3
- OpenSSL SSL_CTX_set_verify
- OpenSSL SSL_CTX_set_cert_verify_callback
- OpenSSL SSL_key_update